

GİRİŞİM LOGISTICS

ZƏİFLİK QIYMƏTLƏNDİRMƏ HESABATI

Hədəf: LOGI-WEB-SRV01 (10.0.2.7) | Tarix: 24 May 2026

Hazırlanmışdır: Girişim Logistics | Hazırladı: Zülfüqar Hüseynli | Metod: Black-Box

1. İCMAL

Bu hesabat Girişim Logistics şirkətinin daxili infrastrukturuna, xüsusilə LOGI-WEB-SRV01 (10.0.2.7) serverinə qarşı aparılmış nüfuz testinin nəticələrini əks etdirir. Test müddətində kritik səviyyəli zəifliklər aşkar edilmiş və sisteminə tam administrator səviyyəsində (NT AUTHORITY\SYSTEM) giriş əldə edilmişdir.

Meyar	Dəyər
Hədəf IP	10.0.2.7
Hədəf Host	LOGI-WEB-SRV01
OS	Windows Server 2019 (10.0.17763.3650)
Test Tarixi	24–25 May 2026
Test Edən	Zülfüqar Hüseynli
Ümumi Risk Səviyyəsi	KRİTİK
Əldə edilən Giriş	NT AUTHORITY\SYSTEM (tam nəzarət)

2. METODOLOGİYA

Test PTES (Penetration Testing Execution Standard) çərçivəsində aşağıdakı mərhələlər üzrə aparılmışdır:

Mərhələ	Fəaliyyət
Kəşfiyyat	Nmap ilə şəbəkə skanı, xidmət və versiya tespiti
Skan / Analiz	Açıq portların tədqiqi, veb tətbiqi analizi
İstismar	Fayl yükləmə bypass, webshell icra, reverse shell
Post-Exploitation	İmtiyaz artırımı, credential tapıntısı, lateral hərəkət
Hesabat	Tapıntıların sənədləşdirilməsi, tövsiyələrin hazırlanması

3. KƏŞFİYYAT VƏ SKAN

3.1 Şəbəkə Skanı

Nmap ilə 10.0.2.0/24 subneti skan edilərək 4 aktiv host aşkar edildi. Hədəf server aşağıdakı açıq portlara malikdir:

Port	Xidmət	Versiya	Qeyd
80/tcp	HTTP	Microsoft IIS 10.0	Veb tətbiq — əsas hücum vektoru
135/tcp	MSRPC	Windows RPC	
139/tcp	NetBIOS	Windows NetBIOS	
445/tcp	SMB	Microsoft-DS	Credential spray üçün istifadə edildi
5985/tcp	WinRM	HTTPAPI 2.0	Uzaqdan idarəetmə

4. AŞKAR EDİLƏN ZƏİFLİKLƏR

4.1 Fayl Yükləmə Filtrasiyasının Bypass Edilməsi

Ciddilik: **[KRİTİK]** CVE: CWE-434 (Unrestricted File Upload)

Veb tətbiqin fayl yükləmə funksiyası yalnız uzantı əsasında yoxlama aparır. İkili uzantı (double extension) texnikası ilə bu filtr keçilmişdir.

İstifadə edilən fayl adı:

```
shell.pdf.aspx
```

Yükləmə yolu:

```
http://10.0.2.7/Uploads/shell.pdf.aspx
```

4.2 Uzaqdan Kod İcrası (RCE) — Webshell

Ciddilik: **[KRİTİK]** CVE: CWE-78 (OS Command Injection)

Yüklənmiş ASPX webshell vasitəsilə serverə PowerShell əmrləri göndərilmiş, base64 ilə kodlanmış reverse shell icra edilmişdir.

İcra edilən əmr:

```
powershell -enc [Base64 encoded reverse shell payload]
```

Nəticə: 10.0.2.3:4444 ünvanına reverse shell bağlantısı quruldu.

4.3 Hardcoded (Açıq) Parol — Backup Skriptdə

Ciddilik: **[KRİTİK]** CVE: CWE-259 (Use of Hard-coded Password)

C:\Backups\db_backup.ps1 faylında administrator parolunun açıq mətndə saxlandığı aşkar edilmişdir:

```
$BackupUser = "LOGI-WEB-SRV01\Administrator"
```

```
$BackupPassword = "LogisticsAdmin2026"
```

4.4 İmtiyaz Artırımı — SelmpersonatePrivilege

Ciddilik: [YÜKSÖK] CVE: CWE-269 (Improper Privilege Management)

IIS worker prosesinin SelmpersonatePrivilege imtiyazına malik olması ilə birlikdə, psexec vasitəsilə tam SYSTEM səviyyəsinə yüksəlmə mümkün oldu.

4.5 Lateral Hərəkət — impacket-psexec ilə SYSTEM Girişi

Ciddilik: [KRİTİK]

Tapılan credential ilə impacket-psexec vasitəsilə SMB üzərindən sisteminə qoşulmuş və tam nəzarət əldə edilmişdir:

```
impacket-psexec Administrator:'LogisticsAdmin2026'@10.0.2.7  
whoami → nt authority\system
```

5. TAPINTILAR ÜMÜMLÜK CƏDVƏLİ

#	Zəiflik	Risk	CVSS (təxmini)
1	Fayl yükləmə bypass (double ext.)	KRİTİK	9.8
2	Webshell vasitəsilə RCE	KRİTİK	9.8
3	Hardcoded administrator parolu	KRİTİK	9.1
4	SelmpersonatePrivilege — privilege escalation	YÜKSÖK	8.2
5	Lateral movement (psexec / SMB)	KRİTİK	9.0

6. TÖVSIYƏLƏR

6.1 Dərhal Tədbirlər (0–7 gün)

- C:\Backups\db_backup.ps1 faylındakı açıq parolu dərhal dəyişdirin.
- LogisticsAdmin2026 parolunu bütün sistemlərdə yenisi ilə əvəz edin.
- Webshell faylını (shell.pdf.aspx) serverdən dərhal silin.
- Yüklənmiş fayllara birbaşa HTTP icra girişini bloklayın (IIS handler konfigurasiyası).

6.2 Qısa Müddətli Tədbirlər (7–30 gün)

- Fayl yükləmə funksiyasını yenidən qurun: uzantı siyahısı, MIME yoxlama, məzmun analizi, fayl adının rename edilməsi.
- Yüklənmiş faylları icra edilə bilməyən ayrıca bir yerə (vəb kökünün xaricinə) köçürün.
- Bütün xidmət hesabları üçün minimum imtiyaz prinsipini tətbiq edin (Least Privilege).
- Parol siyasətini gücləndin: mürəkkəblik, minimum 14 simvol, 90 gün rotasiya.
- Windows Credential Manager və ya HashiCorp Vault kimi gizli məlumat idarəetmə həlli tətbiq edin.

6.3 Uzun Müddətli Tədbirlər (30–90 gün)

- Web Application Firewall (WAF) tətbiq edin.
- SMB giriş nöqtələrini şəbəkə daxilindən segmentasiya ilə məhdudlaşdırın.
- SIEM sistemi qurun, şübhəli PowerShell icrasını monitorinq edin.
- Müntəzəm pentest proqramı tətbiq edin (ildə minimum 2 dəfə).
- Tərtibatçılar üçün təhlükəsiz kodlaşdırma təlimi keçirin.

7. NƏTİCƏ

Test müddətində LOGI-WEB-SRV01 serverinə qarşı uğurla tam nüfuz edilmiş, NT AUTHORITY\SYSTEM səviyyəsində nəzarət əldə edilmişdir. Bu, şirkətin bütün daxili məlumat bazası, fayllar və şəbəkə infrastrukturunun potensial riskə məruz qaldığını göstərir.

Ən kritik problem: açıq məndə saxlanan administrator parolu ilə birlikdə kifayətsiz fayl yükləmə filtrasıdır. Bu iki zəifliyin birliyi, xarici bir hücumçunun sistemi tam ele keçirməsinə imkan verir.

Yuxarıda göstərilən tövsiyələrin ardıcıl şəkildə tətbiq edilməsi infrastrukturun təhlükəsizliyini əhəmiyyətli dərəcədə artıracaqdır.

Bu hesabat yalnız Girişim Logistics rəhbərliyi üçün nəzərdə tutulmuşdur.